UNIVERSIDAD DE LAS FUERZAS ARMADAS ESPE

Ingeniería de Software

KunturChat

Salas de chat seguras, vigiladas desde las alturas

Requisitos funcionales, requisitos de seguridad, propiedades y técnicas

Proyecto Integrador

Asignatura: Desarrollo de Software Seguro
NRC: 36900

Integrantes

Altamirano Ricardo
Ayo Alisson
Valencia Yuliana

Fecha: 14 de octubre de 2026

Índice

1. Introducción y objetivo **2**

2. Contexto y alcance **2**
2.1. Equivalencia con los requisitos originales 2

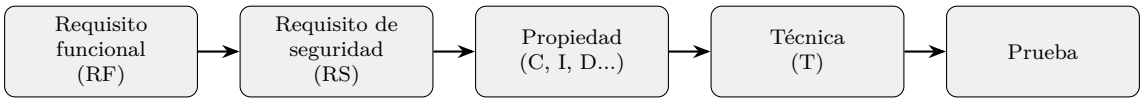
3. Requisitos funcionales **3**

Fuentes de trabajo **3**

1. Introducción y objetivo

KunturChat está en etapa de especificación. Este documento define **qué debe hacer** el sistema (requisitos funcionales) y **cómo debe protegerse** (requisitos de seguridad), y los conecta con las propiedades de seguridad, las técnicas y las pruebas. Todo control es una **propuesta**: todavía no hay implementación verificada.

Cada requisito sigue la misma cadena:
Requisito funcional (RF) → Requisito de seguridad (RS) → Propiedad → Técnica (T) → Prueba.
En palabras simples: *qué hace* el sistema, *qué obligación de seguridad* tiene, *qué protege* esa obligación, *con qué se implementa* y *cómo se comprueba*.



2. Contexto y alcance

Alcance confirmado: administración de salas, mensajes de texto en tiempo real, multimedia PNG/JPEG, conexión única por identidad, criptografía, detección de contenido sospechoso, auditoría y alertas.

Arquitectura propuesta: cliente web, consola administrativa, APIs, WebSocket, base de datos relacional, almacenamiento de sesiones, analizador aislado y registros separados.

Audio y video quedan fuera del alcance. TLS protege los datos durante el tránsito, pero no constituye cifrado de extremo a extremo, ya que el servidor debe analizar las imágenes. La clave de una sala no identifica a una persona; además, una conexión por identidad no impide que una misma persona utilice varias cuentas. La identidad estable, la descarga autorizada y la consulta de auditoría se consideran propuestas adicionales.

2.1. Equivalencia con los requisitos originales

El enunciado original tenía nueve requisitos (RF01–RF09). Para poder verificarlos mejor se separaron en 14 requisitos funcionales y 15 de seguridad.

Original	Sentido	Equivalencia actual
RF01	Autenticación administrativa	RF-01; RS-01, RS-02
RF02	Gestión de salas	RF-02
RF03	Atributos de sala	RF-03; RS-04
RF04	Conexión única	RF-07, RF-08; RS-06
RF05	Autenticación y autorización	RF-04, RF-05; RS-02, RS-03, RS-05, RS-11
RF06	Protección de la comunicación	RF-06; RS-07, RS-08, RS-09
RF07	Validación multimedia	RF-09, RF-10, RF-11; RS-10
RF08	Esteganografía	RF-10; RS-12
RF09	Auditoría y alertas	RF-12, RF-13, RF-14; RS-13

3. Requisitos funcionales

Un requisito funcional dice **qué debe hacer el sistema**.

Código	Requisito funcional	Descripción	Actor	Prioridad
RF-01	Inicio administrativo	Permitir iniciar sesión administrativa solo después de validar credenciales y código TOTP.	Administrador	Alta
RF-02	Gestión de salas	Permitir al administrador autorizado crear, modificar, consultar y cerrar salas. Una sala cerrada no admite ingresos.	Administrador	Alta
RF-03	Configuración de sala	Definir para cada sala un identificador independiente, una clave, un aforo máximo y una modalidad (texto o multimedia).	Administrador	Alta
RF-04	Ingreso de participantes	Admitir al participante solo si la sala está activa, la clave es correcta, está identificado y hay aforo disponible.	Participante / backend	Alta
RF-05	Identidad estable (propuesta)	Asignar un identificador estable que asocie sesiones y eventos, sin presentarlo como prueba de identidad física.	Participante / backend	Media
RF-06	Texto en tiempo real	Permitir a los miembros activos enviar y recibir mensajes dentro de su sala.	Participante	Alta
RF-07	Conexión única	Impedir dos conexiones simultáneas para la misma identidad.	Backend	Alta
RF-08	Cierre de sesión	Cerrar la conexión y revocar el acceso asociado.	Administrador / participante	Alta
RF-09	Carga de imágenes	Recibir imágenes PNG o JPEG en una sala multimedia y dejarlas en cuarentena antes de publicarlas.	Participante / analizador	Alta
RF-10	Clasificación multimedia	Clasificar cada imagen como aprobada, rechazada, sospechosa o análisis fallido. Solo se publica la aprobada.	Analizador	Alta
RF-11	Descarga autorizada (propuesta)	Permitir descargar una imagen solo a miembros autorizados de su sala.	Participante / backend	Media
RF-12	Registro de seguridad	Registrar eventos con identidad técnica, fecha, acción, objeto y resultado.	Servicios internos	Alta
RF-13	Alertas	Alertar sobre intentos reiterados, archivos sospechosos, alteración de auditoría y eventos de alto riesgo.	Servicios / administrador	Alta
RF-14	Consulta de eventos (propuesta)	Permitir al administrador autorizado consultar eventos sin poder alterar las evidencias.	Administrador	Media

Bibliografia

- Proyecto integrador: requisitos originales, arquitectura, activos, riesgos y políticas.
- Apuntes de clase: riesgo, tríada C-I-D, autenticación, autorización y auditoría; gestión de vulnerabilidades, SAST/DAST y monitoreo.
- Análisis y tratamiento de riesgos de KunturChat (documento anterior del equipo).
- Rose, S., Borchert, O., Mitchell, S. y Connelly, S. (2020). *Zero Trust Architecture*. NIST SP 800-207.

- OWASP Foundation. *Cheat Sheet Series* (sesiones, contraseñas, WebSocket, inyección SQL, subida de archivos y registros). `https://cheatsheetseries.owasp.org`
- Rescorla, E. (2018). *The Transport Layer Security Protocol Version 1.3*. RFC 8446.